PROJECT REPORT

Active Directory Attack Lab: Built a Virtual Windows Domain to Test Kerberoasting and GPO Hardening

Project type: Cybersecurity / Windows Domain Security Lab
Focus: Defensive assessment, service-account exposure review, and Group Policy hardening
Institution: Sandip University (logo supplied by user)

Abstract

This project outlines an isolated virtual Windows domain used to study Active Directory security from a defensive perspective. The work focuses on identifying service accounts associated with Service Principal Names (SPNs), reviewing selected indicators that can increase Kerberoasting risk, and evaluating a small set of Group Policy Object (GPO) hardening controls. A Python utility processes a sanitized JSON inventory and produces a structured findings report. The utility is deliberately offline and does not request service tickets, extract credentials, crack passwords, connect to a domain, or modify policy.

1. Introduction

Active Directory provides centralized identity, authentication, and policy management in many Windows environments. Mismanaged service accounts, weak or stale credentials, legacy encryption configurations, and inconsistent security policies can increase the risk of credential compromise. A controlled virtual lab allows these issues to be studied without exposing production systems.

2. Problem Statement

Administrators need a repeatable way to review service-account/SPN inventory and selected domain hardening settings, identify missing or potentially risky configurations, and document remediation priorities. Manual review can be inconsistent, while changes made without validation may disrupt applications. This project provides an offline screening workflow and a reproducible report format.

3. Objectives

- Build a virtual Windows domain in an isolated network.
- Review SPN-bearing service accounts and selected credential-hygiene indicators.
- Check selected GPO hardening values against documented expectations.
- Generate machine-readable findings and remediation suggestions.
- Document limitations and recommend safe validation steps.

4. Scope and Ethical Boundaries

The project is restricted to systems owned by or explicitly authorized for the lab. The included Python tool analyzes a provided inventory file only. It performs no network actions and does not conduct ticket extraction, credential dumping, password cracking, exploitation, persistence, or policy changes. Any hands-on lab exercises should use synthetic accounts, isolated virtual networking, snapshots, and institution-approved procedures.

5. Proposed Lab Architecture

Component	Purpose
Windows Server VM	Domain controller for the isolated lab domain; hosts directory and Group Policy services.
Windows client VM(s)	Join the lab domain and support policy verification from a client perspective.
Host-only / isolated virtual switch	Keeps lab traffic separate from production networks.
Python audit utility	Analyzes sanitized JSON inventory and emits a findings report.

6. Methodology

Phase 1 — Plan: Define lab scope, VM resources, network isolation, and evidence to collect.
Phase 2 — Build: Configure a Windows domain in the virtual environment and create non-production test accounts and OUs.
Phase 3 — Inventory: Record approved service-account metadata, SPNs, password age indicators, encryption settings, and effective GPO values. Do not record secrets.
Phase 4 — Audit: Run the Python script against the JSON inventory.
Phase 5 — Remediate and validate: Review findings, apply changes manually in the lab, and verify application behavior and effective policy.
Phase 6 — Report: Compare before/after observations and document remaining risks.

7. Kerberoasting Exposure Review

An SPN associates a service instance with an account. SPN-bearing accounts warrant review because service-ticket material can be targeted offline in Kerberoasting attacks. The presence of an SPN alone does not prove that an account is exploitable. Review whether the account is managed, whether its secret is sufficiently long and random, whether privileges are limited, and whether modern encryption is supported. Prefer Group Managed Service Accounts (gMSAs) when supported, and monitor unusual service-ticket patterns.

8. GPO Hardening Checks

Setting	Screening expectation	Purpose
Minimum password length	At least 14 characters	Strengthen password policy where applicable.
Account lockout threshold	Positive value, no greater than 10	Limit repeated failed logons; assess denial-of-service trade-offs.
LM hash storage	Disabled	Avoid legacy password-hash storage.
SMBv1	Disabled	Reduce exposure to obsolete protocol risks.
Windows Firewall	Enabled	Maintain host firewall protection.
PowerShell Script Block Logging	Enabled	Improve visibility for script activity; consider log retention.
LDAP signing	Required	Help protect LDAP integrity; test compatibility.

9. Python Utility Design

The script reads a JSON file, validates its top-level structure, checks service-account records and selected GPO values, and writes a JSON report. A finding is classified as HIGH or MEDIUM for service-account review, or REVIEW / NOT_VERIFIED for GPO checks. Settings that meet the configured expectation are omitted from the findings list. The tool includes recommendations but does not apply any changes.

10. Execution

```
python active_directory_attack_lab.py --input sample_inventory.json --output audit_report.json
```

The included sample inventory is synthetic and is intended only to demonstrate expected input formatting and output generation.

11. Expected Outcomes

- A repeatable offline review of service-account metadata and selected GPO settings.
- A JSON report that supports review, prioritization, and evidence collection.
- Improved understanding of SPN-related risk and common Windows domain hardening controls.
- A documented lab workflow that can be repeated after configuration changes.

12. Limitations

The audit is a screening aid, not a comprehensive vulnerability scanner. It does not query the domain directly, verify the effective GPO result, assess every account attribute, validate all encryption negotiation behavior, or prove exploitability. Input completeness and correctness determine the quality of the findings. Independent verification is required.

13. Conclusion

This project demonstrates a controlled, defensive workflow for examining selected Active Directory service-account and Group Policy risks. The combination of an isolated virtual domain, sanitized inventory, and an offline Python audit supports repeatable assessment and clear documentation. Future extensions could add signed inventory exports, CSV input, risk scoring aligned to an approved baseline, and comparison of before/after audit reports, while retaining the no-exploitation design.

References and Further Reading

- Microsoft Learn — Group Managed Service Accounts (gMSA) documentation.
- Microsoft Learn — Security policy settings and Group Policy documentation.
- MITRE ATT&CK; — T1558.003, Kerberoasting (for defensive understanding and detection context).
- Microsoft security baselines and applicable organizational hardening standards.